Data Protection and Privacy Policy

Privacy office · POL-DP-03 · Version 5.2 · Effective 1 April 2026

> Fictional sample document for testing a domain-specialist RAG. Requirements are cited as, for example, "DP-05".

1. Classification and minimisation

DP-01 Every data field is classified as Public, Internal, Confidential or Restricted. Government IDs, payment data, health data and precise location are Restricted.

DP-02 Collect only data needed for a stated purpose. Each new use of personal data needs a documented purpose in the data inventory.

2. Consent and rights

DP-03 Marketing communications need explicit opt-in consent, recorded with time and channel. Withdrawing consent must be as easy as giving it and take effect within 48 hours.

DP-04 Requests to access, correct or delete personal data are completed within 30 days. Deletion covers backups within their normal expiry cycle.

DP-05 Processing personal data of children under 18 requires verifiable parental consent; profiling and targeted advertising to children is prohibited.

3. Retention

Data	Maximum retention
Customer account and profile data	3 years after account closure
Transaction records	8 years (tax and audit law)
Application logs	30 days
Support call recordings	90 days
Marketing analytics events	13 months, pseudonymised

DP-06 Retention periods in the table are maximums and are enforced automatically; manual deletion is not sufficient.

4. Security and location

DP-07 Confidential and Restricted data is encrypted at rest (AES-256) and in transit (TLS 1.2 or newer).

DP-08 Personal data of Indian customers is stored and processed in India (Mumbai or Hyderabad regions). Transfers abroad need approval from the privacy office and a contract with

the recipient.

DP-09 Analytics and machine-learning datasets use pseudonymised identifiers. Raw email addresses, phone numbers and names must not enter analytics tools.

DP-10 Access to Restricted data is role based, reviewed every quarter, and logged.

5. Vendors, assessments and breaches

DP-11 Every vendor that processes personal data signs a data processing agreement before receiving data.

DP-12 A data protection impact assessment (DPIA) is completed before launching any new processing of Restricted data, large-scale profiling, or AI that makes decisions about individuals.

DP-13 Suspected personal data breaches are reported to the privacy office within 1 hour of discovery. The privacy office notifies authorities and affected customers as required by law.

DP-14 Personal data must not be sent to external AI services unless the vendor contract forbids training on it and the data stays in an approved region.